Enumeración y vulnerabilidades

© **Universidad de Palermo** | Prohibida la reproducción total o parcial de imágenes y textos.

UP
Universidad de Palermo

Escaneo de vulnerabilidades

El escaneo de vulnerabilidades nos permite rápidamente detectar vulnerabilidades conocidas en el equipo/servicio objetivo.

Los sistemas que realizan estos escaneos nos darán el nombre de la vulnerabilidad, criticidad, descripción, host asociado, puerto y protocolo, recomendaciones y CVE asociado, entro otros datos de interés.

UP Universidad de Palermo ©

Escaneo y enumeración

En esta fase recogeremos toda la información descubierta durante el Footprinting o reconocimiento y la usaremos para explorar la red.

Hay tres tipos de escaneo:

- El **escaneo de puertos**, donde se determinan los puertos TCP/IP abiertos y disponibles.
- El **escaneo de red**, donde se determinan los host que se encuentran activos.
- El **escaneo de vulnerabilidades**, donde se determina la existencia de vulnerabilidades conocidas en los host.

UP Universidad de Palermo ©

Escaneo y enumeración

Junto al Footprinting, el Escaneo y la Enumeración son las tres fases de obtención de información previas a un ataque.

Estas tres fases, tienen por objeto encontrar sistemas o redes objetivo.

El proceso de Enumeración comienza una vez finalizado el Escaneo y su objetivo es el de enumerar e identificar los nombres de los equipos, usuarios y recursos compartidos entre otra información de valor.

Ambas fases suelen ser estudiadas en conjunto, puesto que la mayoría de las herramientas disponibles realizan ambas tareas.

UP Universidad de Palermo ©

Escaneo de vulnerabilidades

Scanners de vulnerabilidades conocidos:

- nmap
- Nessus
- OpenVAS
- Acunetix
- Burp
- OWASP ZAP, etc.

UP Universidad de Palermo ©

nmap



Fuente: Ejecución de la aplicación nmap [captura de pantalla]

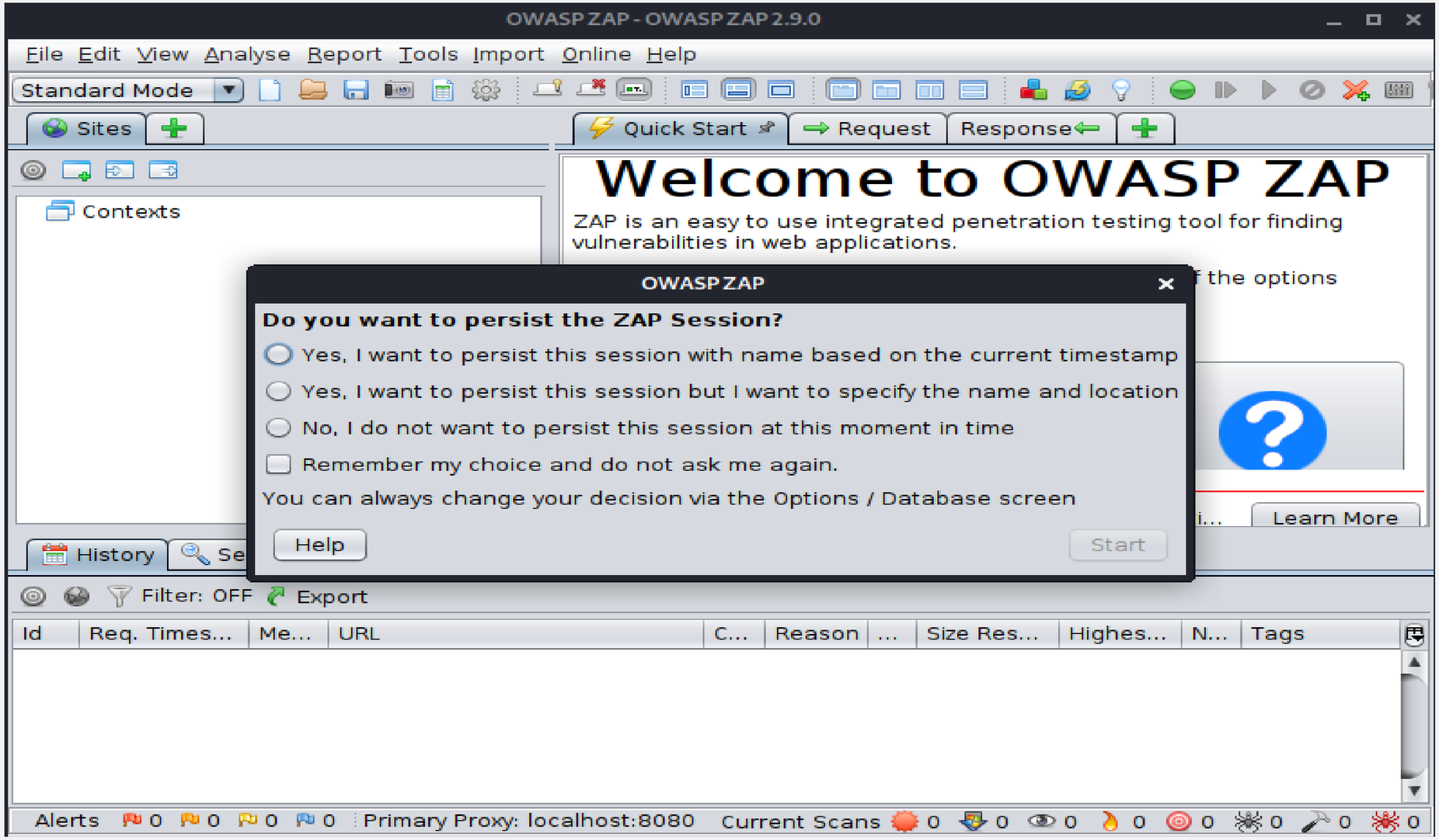
nikto

```
root@kali:~# nikto -Help

   Options:
      -ask+               Whether to ask about submitting updates
                              yes   Ask about each (default)
                              no    Don't ask, don't send
                              auto  Don't ask, just send
       -Cgidirs+          Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"
       -config+           Use this config file
       -Display+          Turn on/off display outputs:
                              1     Show redirects
                              2     Show cookies received
                              3     Show all 200/OK responses
                              4     Show URLs which require authentication
                              D     Debug output
                              E     Display all HTTP errors
                              P     Print progress to STDOUT
                              S     Scrub output of IPs and hostnames
                              V     Verbose output
       -dbcheck           Check database and other key files for syntax errors
       -evasion+          Encoding technique:
                              1     Random URI encoding (non-UTF8)
                              2     Directory self-reference (/./)
                              3     Premature URL ending
                              4     Prepend long random string
                              5     Fake parameter
                              6     TAB as request spacer
                              7     Change the case of the URL
                              8     Use Windows directory separator (\)
                              A     Use a carriage return (0x0d) as a request spacer
                              B     Use binary value 0x0b as a request spacer
        -Format+          Save file (-o) format:
                              csv   Comma-separated-value
                              json  JSON Format
                              htm   HTML Format
                              nbe   Nessus NBE format
                              sql   Generic SQL (see docs for schema)
                              txt   Plain text
                              xml   XML Format
```

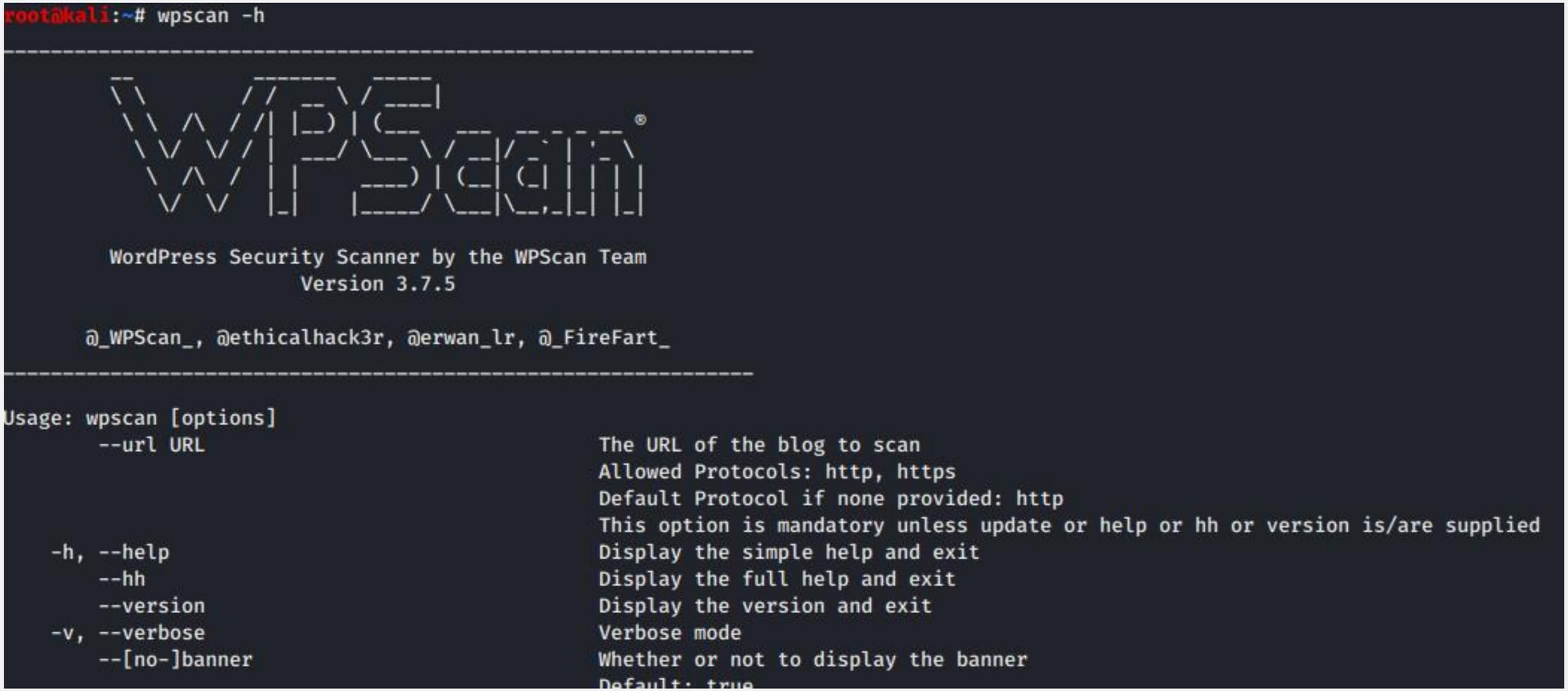
Fuente: Ejecución de la aplicación nikto [captura de pantalla]

ZAP



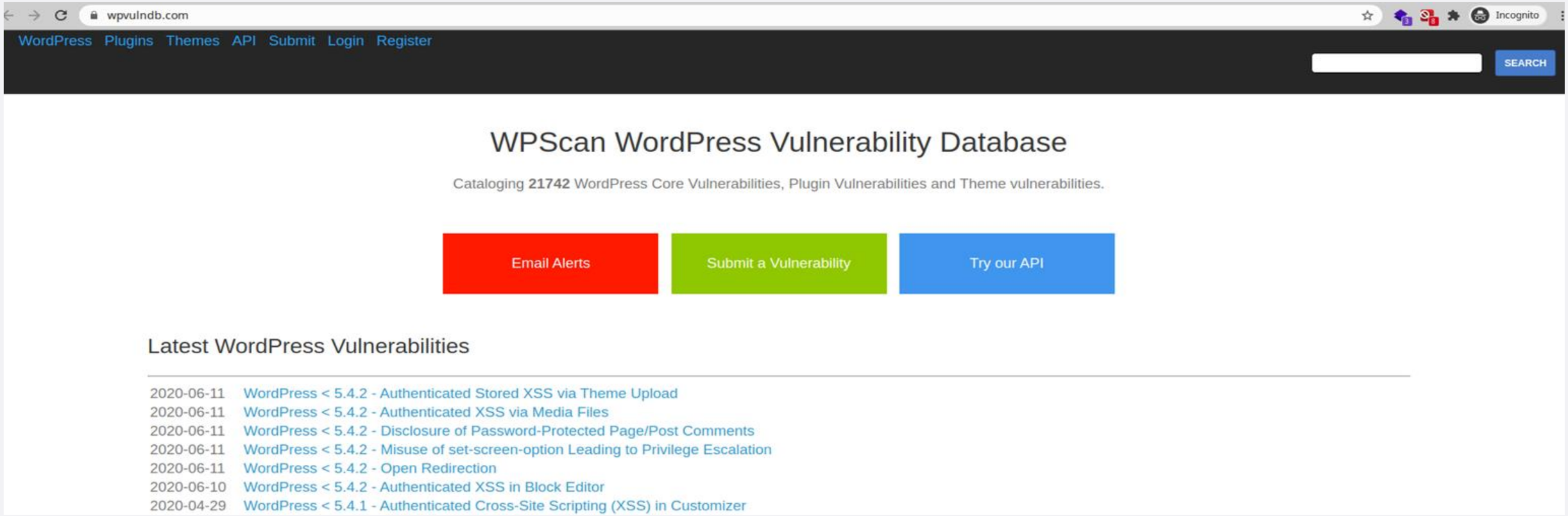
Fuente: Ejecución de la aplicación owaspzap [captura de pantalla]

wpscan



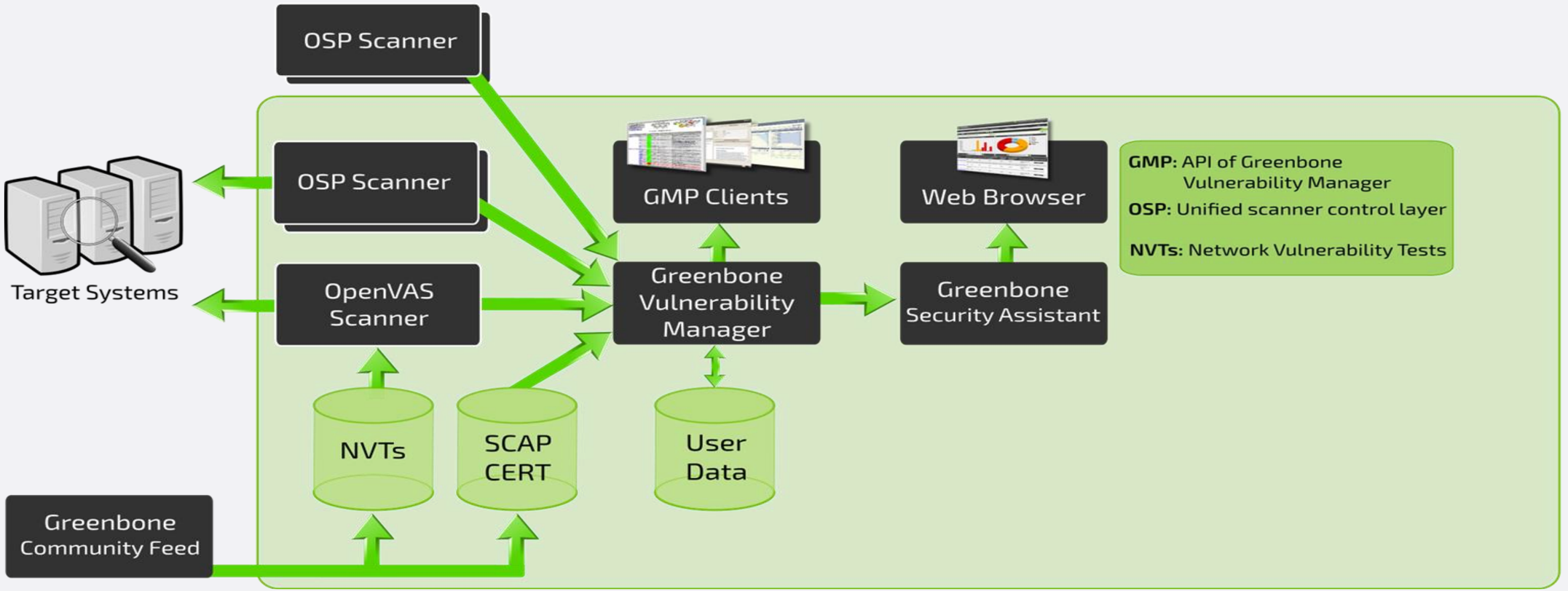
Fuente: Ejecución de la aplicación wpscan [captura de pantalla]

wpvulndb



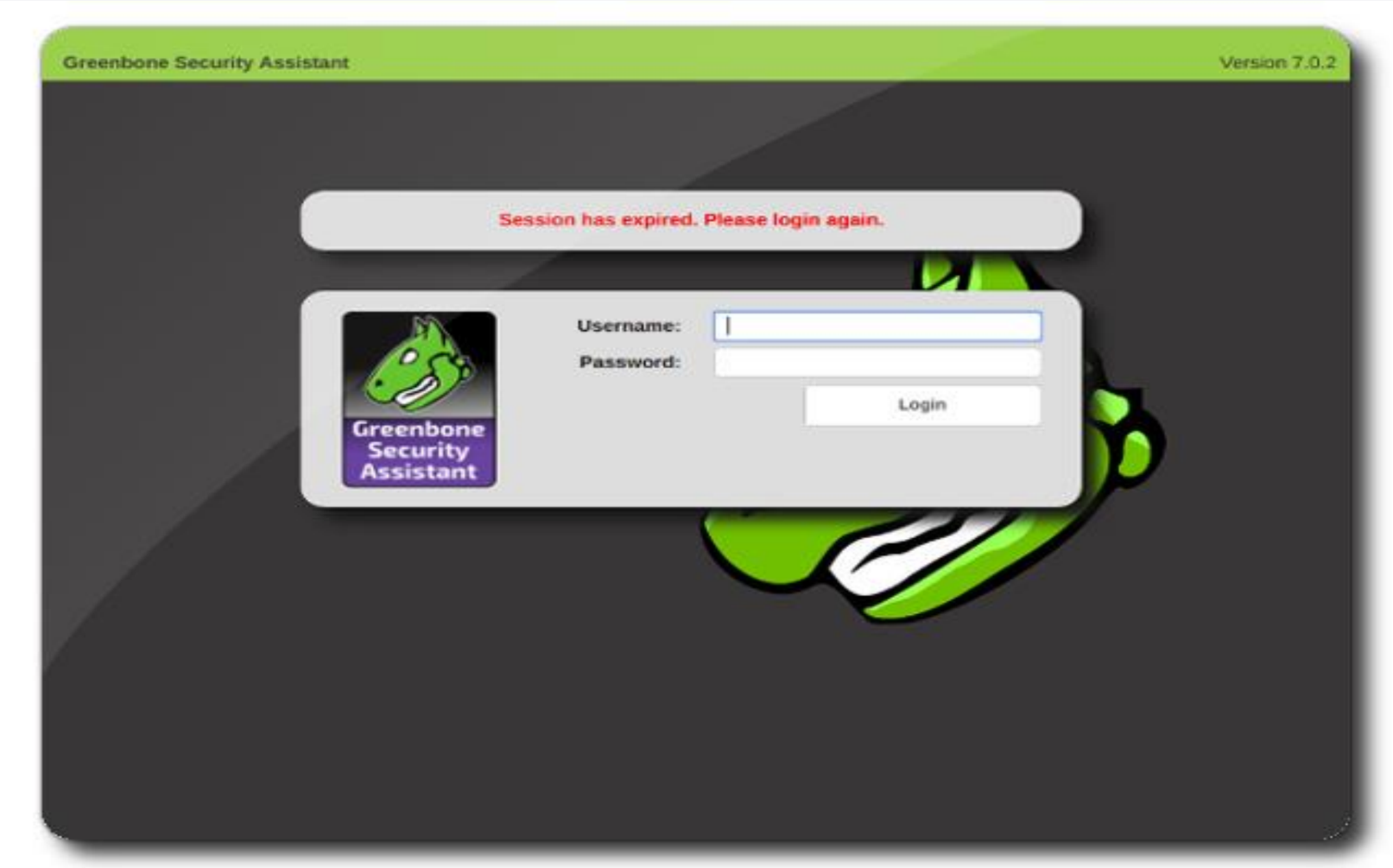
Fuente: Ejecución de la aplicación wpvulndb [captura de pantalla]

OpenVAS



Fuente: Ejecución de la aplicación OpenVAS [captura de pantalla]

OpenVAS



Fuente: https://www.turnkeylinux.org/screenshots/openvas-login



© Universidad de Palermo
Prohibida la reproducción total o parcial de imágenes y textos.